

In questa giornata del corso ho approfondito la fase di *Vulnerability Assessment (VA)* , ovvero la valutazione delle vulnerabilità presenti nei sistemi informatici. Questo rappresenta una tappa fondamentale nel processo di ethical hacking: permette di individuare configurazioni errate, servizi esposti o software non aggiornati, assegnando loro un livello di rischio. A differenza del Penetration Test , questa fase non include l'exploitation, ma prepara il terreno per eventuali exploit futuri.

L'obiettivo principale dell'esercitazione era effettuare una serie di scansioni con **Nmap** su un sistema **Windows** , sia con il **firewall attivo** che **disattivato** , al fine di confrontare i risultati ottenuti. Inoltre, è stato richiesto di documentare ogni passaggio, mostrare i comandi utilizzati e commentare le differenze osservate.

Configurazione della Rete

Prima di procedere con le scansioni vere e proprie, ho configurato due macchine virtuali su VMware:

- **Kali Linux** : utilizzato come sistema attaccante.
- **Windows 10/11** : il target da analizzare.

Ho assicurato che entrambe fossero sulla stessa rete virtuale e che potessero comunicare tra loro. Ho verificato la connettività tramite il comando `ping` e ho controllato gli indirizzi IP:

- **Kali Linux** : 192.168.222.129
- **Windows** : 192.168.222.128

Dopo aver confermato la comunicazione reciproca, sono passato alle scansioni con Nmap.

Scansioni con Firewall Attivo

Come prima cosa, ho lasciato il firewall di Windows abilitato e ho lanciato diverse tipologie di scansione con Nmap da Kali Linux.

Considerazione : Con il firewall attivo, il sistema Windows appare molto più “invisibile” alla scansione esterna. Le porte non vengono mostrate, i servizi non sono riconoscibili e il sistema sembra quasi non esistere per l'attaccante.

```
nmap -sV 192.168.222.128
nmap -O 192.168.222.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:09 EDT
Nmap scan report for 192.168.222.1
Host is up (0.00023s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.222.128
Host is up (0.00012s latency).
MAC Address: 00:0C:29:05:2A:48 (VMware)
Nmap scan report for 192.168.222.254
Host is up (0.00019s latency).
MAC Address: 00:50:56:E6:3C:88 (VMware)
Nmap scan report for 192.168.222.129
Host is up.
Nmap scan report for 192.168.222.131
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 27.89 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:09 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00025s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 34.37 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:10 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00030s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 34.28 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:10 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00034s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 open|filtered udp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 34.38 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:11 EDT
```

```
Nmap done: 1 IP address (1 host up) scanned in 34.37 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:10 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00030s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 34.28 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:10 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00034s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 open|filtered udp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 34.38 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:11 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00037s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.44 seconds
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:12 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00030s latency).
All 1000 scanned ports on 192.168.222.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:05:2A:48 (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.97 seconds
```

Scansioni con Firewall Disattivato

A questo punto, ho disattivato temporaneamente il firewall di Windows, usando PowerShell con privilegi elevati:

Con il firewall disattivato, Nmap è riuscito a riconoscere chiaramente che si trattava di un sistema Windows, probabilmente tra la versione 7 e 10.

Considerazione : Senza il firewall, il sistema diventa molto più visibile e vulnerabile. I servizi esposti possono essere sfruttati, e la versione del sistema operativo è facilmente identificabile.

File Actions Edit View Help

(kali㉿kali)-[~]

\$ nmap -sn 192.168.222.0/24

Starting Nmap 7.95 (<https://nmap.org>) at 2025-05-09 11:42 EDT

Nmap scan report for 192.168.222.1

Host is up (0.00021s latency).

MAC Address: 00:50:56:C0:00:01 (VMware)

Nmap scan report for 192.168.222.128

Host is up (0.00026s latency).

MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap scan report for 192.168.222.254

Host is up (0.000085s latency).

MAC Address: 00:50:56:E6:3C:88 (VMware)

Nmap scan report for 192.168.222.129

Host is up.

Nmap scan report for 192.168.222.131

Host is up.

Nmap done: 256 IP addresses (5 hosts up) scanned in 27.91 seconds

(kali㉿kali)-[~]

\$ ping 192.168.222.128

PING 192.168.222.128 (192.168.222.128) 56(84) bytes of data.

■

(kali㉿kali)-[~]

\$ nmap -sS 192.168.222.128

Starting Nmap 7.95 (<https://nmap.org>) at 2025-05-09 11:54 EDT

Nmap scan report for 192.168.222.128

Host is up (0.00032s latency).

Not shown: 991 closed tcp ports (reset)

PORT	STATE	SERVICE
------	-------	---------

135/tcp	open	msrpc
---------	------	-------

139/tcp	open	netbios-ssn
---------	------	-------------

445/tcp	open	microsoft-ds
---------	------	--------------

49152/tcp	open	unknown
-----------	------	---------

49153/tcp	open	unknown
-----------	------	---------

49154/tcp	open	unknown
-----------	------	---------

49155/tcp	open	unknown
-----------	------	---------

49156/tcp	open	unknown
-----------	------	---------

49157/tcp	open	unknown
-----------	------	---------

MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.45 seconds

Nmap done: 1 IP address (1 host up) scanned in 16.17 seconds

(kali@kali)-[~]

\$ nmap -sU 192.168.222.128

Starting Nmap 7.95 (<https://nmap.org>) at 2025-05-09 11:55 EDT

Stats: 0:03:46 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Stats: 0:03:47 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Stats: 0:03:47 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Stats: 0:03:49 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Stats: 0:03:49 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Stats: 0:03:50 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan

UDP Scan Timing: About 99.99% done; ETC: 11:59 (0:00:00 remaining)

Nmap scan report for 192.168.222.128

Host is up (0.00032s latency).

Not shown: 907 closed udp ports (port-unreach), 92 open|filtered udp ports (no-response)

PORT STATE SERVICE

137/udp open netbios-ns

MAC Address: 00:0C:29:05:2A:48 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 237.80 seconds

(kali@kali)-[~]

\$ nmap -sV 192.168.222.128

Starting Nmap 7.95 (<https://nmap.org>) at 2025-05-09 12:00 EDT

Nmap scan report for 192.168.222.128

Host is up (0.00019s latency).

Not shown: 991 closed tcp ports (reset)

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

135/tcp	open	msrpc	Microsoft Windows RPC
---------	------	-------	-----------------------

139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
---------	------	-------------	-------------------------------

445/tcp	open	microsoft-ds	Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
---------	------	--------------	--

49152/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

49153/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

49154/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

49155/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

49156/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

49157/tcp	open	msrpc	Microsoft Windows RPC
-----------	------	-------	-----------------------

MAC Address: 00:0C:29:05:2A:48 (VMware)

Service Info: Host: WIN-UV09VJTFD3R; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 73.36 seconds

```

(kali@kali)-[~]
$ nmap -sV 192.168.222.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:00 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00019s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49155/tcp  open  msrpc        Microsoft Windows RPC
49156/tcp  open  msrpc        Microsoft Windows RPC
49157/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:05:2A:48 (VMware)
Service Info: Host: WIN-UV09VJTFD3R; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 73.36 seconds

```

```

(kali@kali)-[~]
$ nmap -O 192.168.222.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-09 12:04 EDT
Nmap scan report for 192.168.222.128
Host is up (0.00035s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 00:0C:29:05:2A:48 (VMware)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Server 2008 R2 SP1 or Windows 7 SP1, Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.68 seconds

```

Confronto Risultati: Firewall ON vs OFF

Tipo di Scansione	Risultato con FW On	Risultato con FW Off
-sn(Ping Sweep)	Host rilevato	Host rilevato
-sS(SYN Scan)	Nessuna porta aperta	Porte aperte individuate
-sT(TCP Connect)	Nessuna porta aperta	Porte aperte individuate
-sU(UDP Scan)	Nessuna porta UDP visibile	Individuata porta 137/udp(NetBIOS)
-sV(Service Detect)	Servizi non riconosciuti	Servizi e versioni ben identificate
-O(OS Detection)	OS non riconosciuto	Sistema riconosciuto come Windows

Osservazione finale: La presenza del firewall ha ridotto drasticamente la superficie d'attacco visibile dall'esterno. Molti servizi non sono stati rilevati, e nemmeno la versione del sistema operativo è stata facile da individuare. Tuttavia, con il firewall disattivato, il sistema è diventato molto più debole e facilmente attaccabile.

Conclusioni

Questo esercizio mi ha aiutato a comprendere quanto sia importante il firewall in un sistema operativo, soprattutto per proteggere porte sensibili come quelle dei servizi SMB (445/tcp) o RPC (135/tcp). Lavorando con Nmap, ho imparato a riconoscere le principali tipologie di scansione e a interpretarne i risultati. Ho anche visto come cambia radicalmente il comportamento di un sistema a seconda dello stato del firewall.

Sebbene il firewall non blocchi completamente un attaccante avanzato, riesce comunque a rendere il lavoro molto più difficile, nascondendo informazioni preziose come il sistema operativo e i servizi esposti.